

Phase-1 Brainstroming and Ideation

Date	28-09-2026
Team ID	SWTID-2026-7624
Project Name	Script-controlled ACL
Maximum Marks	4 Mark

Brainstorming

Brainstorming is the first step of the project development process. It is a creative process in which different ideas are discussed to identify a problem and find possible solutions. In this project, brainstorming is used to understand how record access can be restricted based on the value of a particular field.

The main problem identified is that role-based access alone may not be sufficient to control access to every record. For example, records may belong to different departments such as IT, HR, and Finance. A user may need access only to records where the Department field is set to IT.

During brainstorming, the following ideas were considered:

- Restrict record access based on a specific field value.
- Use a script to make the access decision dynamically.
- Check the current user's role before allowing access.
- Combine user role and field value for better security.
- Allow or deny access depending on the conditions.
- Avoid creating many separate static ACL rules.

From these discussions, the idea of using a Script-Controlled ACL was identified as a suitable approach for providing flexible and dynamic record access control.



Brainstorming and Ideation Phase

Script-Controlled ACL – Restrict Record Access Based on Field Values

1 Problem / Idea Generation

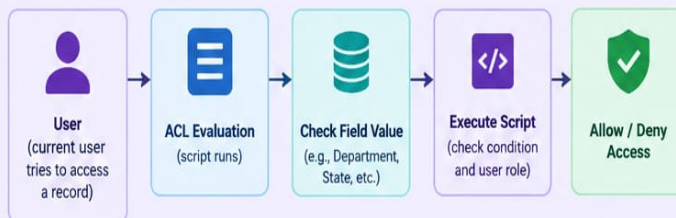
- How can we restrict record access based on the value of a specific field?
- Instead of creating multiple static ACLs, can we use a script to make the decision dynamically?
- This will give more flexibility and control compared to role-based access alone.



2 Key Ideas Discussed

- ✓ **Field-Based Access** – Restrict access depending on a field value (e.g., State, Priority, Department, Approval Status).
- ✓ **Dynamic Security** – Use a script in the ACL instead of multiple static rules.
- ✓ **User Validation** – Check if the current user meets the required condition.
- ✓ **Unauthorized Access Prevention** – Block users from viewing or modifying records that don't meet the criteria.
- ✓ **Role + Condition** – Combine existing user roles with field-based conditions for stronger security.
- ✓ **Different Access Levels** – Set separate rules for read, write, create and delete operations.
- ✓ **Simple Demonstration** – Use sample records with different field values to show allowed and restricted access.

3 Proposed Concept



4 Example Scenario

Allow access only to records where Department = IT.

Sample Records

Record No	Name	Department	Status
R001	Server Upgrade	IT	Open
R002	Website Update	HR	Open
R003	Security Patch	IT	Closed
R004	Office Setup	Finance	Open

5 ACL Script Logic (Example)

```
var user = gs.getUser();
var record = current;

// Allow only if department is IT and user has the required role
if (record.department == 'IT' && user.hasRole('it_user')) {
  answer = true;
} else {
  answer = false;
}
```

JavaScript

What the Script Does

- Gets the current user
- Checks the record's Department field value
- Verifies if the user has the required role
- Grants or denies access (answer = true/false)

6 Final Idea



Implement a Script-Controlled ACL that evaluates a specific field value at runtime and grants or denies access accordingly.

Result

- ✓ Flexible and dynamic access control
- ✓ Field-level record security
- ✓ Better data protection
- ✓ Easy to manage and extend

Right Data + Right People + Right Access = Secure Organization

1. Problem Statement

In organizational and institutional environments, granting unrestricted access to sensitive data poses significant security risks. Standard Role-Based Access Control (RBAC) often falls short because access must frequently be restricted not only by user roles but also dynamically evaluated against specific field values within individual records.

2. Project Objective

The objective of this project is to implement a Script-Controlled Access Control List (ACL) in ServiceNow.

- * **Field-Based Restriction:** Ensure that users with specific roles (e.g., bb1 for EEE branch users) can only view records where the Branch field is explicitly set to EEE.
- * **Administrative Override:** Maintain full, unrestricted access across all records for System Administrators (admin role).
- * **Granular CRUD Operations:** Define clear boundaries for Reading, Creating, Writing, and Deleting records using custom roles.

3. System Architecture & Components

A. User & Role Management

- * **Test User Creation:** Create a test user (e.g., EEE User with email `eeeuser@gmail.com`).
- * **Custom Roles:**
 - * **bb1:** Grants Read permissions for EEE branch records.
 - * **bb2:** Grants Create permissions to add new records.
 - * **bb3:** Grants Write / Edit permissions to modify existing records.
 - * **bb4:** Grants Delete permissions to remove records.

B. Database Design (Custom Table Structure)

- * **Table Label:** Institution Details
- * **Table Name:** `u_institution_details`
- * **Fields:**
 - * **Student Roll Number:** Auto Number
 - * **Student Name:** Reference (to `sys_user`)
 - * **Faculty Name:** Reference (to `sys_user`)
 - * **Branch:** Choice (ECE, EEE, CSE)
 - * **Email:** String
 - * **Phone Number:** String
 - * **Description:** Multi-Line String

C. Security & Access Control Logic

* Scripted Read ACL Logic: Elevate to security_admin and implement an advanced script evaluation:

```
(function () {  
  // Allow admin users full access  
  if (gs.hasRole('admin')) {  
    return true;  
  }  
  // Allow only EEE branch users to see EEE records  
  if (gs.hasRole('bb1')) {  
    return true;  
  }  
  // Deny access for all others  
  return false;  
})();
```

* Operational ACLs: Create separate ACL entries for Create, Write, and Delete assigned to roles bb2, bb3, and bb4 respectively.

4. Execution & Validation Plan

* Impersonation Testing: Use ServiceNow's user impersonation feature to log in as EEE User and verify record visibility.

* Success Criteria:

- * Users with role bb1 can view only EEE branch records.
- * Users without designated roles are blocked from accessing records.
- * Admins maintain global visibility across all branches (ECE, EEE, CSE).